PrivateNote Enterprise

Self-Hosted Docker Image Launch Checklist

A detailed implementation checklist for launching a credible enterprise self-hosted PrivateNote deployment.

Scope
This document defines what must be implemented before launching a paid or customer-facing self-hosted Docker image. It separates the current Docker Compose preview from the production enterprise runtime expected by banks, law firms, and security-sensitive buyers.

Launch Track	Meaning	Status
Developer Preview	Runs current app in containers using Wrangler local runtime for Cloudflare-compatible bindings.	Started
Enterprise Beta	Runs without Cloudflare account dependency, with standard databases, admin controls, and documented operations.	Target
Enterprise GA	Adds hardening, SSO/SCIM, audit export, signed images, SBOM, SLA docs, and procurement artifacts.	Future

Prepared for PrivateNote.ai product and engineering planning. Version 1.0.

Executive Summary

The self-hosted Docker image should not be launched as a serious enterprise product until it is more than a containerized development environment. Enterprise buyers need a predictable deployment model, customer-controlled storage, identity integration, auditability, policy controls, documented operations, and a clear security story.

The current Docker Compose work is a useful foundation, but the production self-hosted edition needs a native on-prem runtime that does not rely on Wrangler or Cloudflare local emulation.

> **MVP Cutline**
> The first credible MVP should include: production Docker Compose, PostgreSQL storage, OIDC login, organization/admin/member model, audit logs and export, retention policies, internal-only mode, API tokens, backup/restore docs, and a security architecture document.

Definition Of Launch

Launch Level	Allowed Use	Minimum Standard
Preview	Internal demos, engineering validation, friendly testers.	Can rely on Wrangler local runtime, but must be labeled clearly as preview.
Enterprise Beta	Design partners with technical support and explicit limitations.	Native API container, customer-controlled DB, OIDC, admin console, audit logs, documented backup/restore.
GA	Paid enterprise deployments for regulated buyers.	Hardening, signed images, SBOM, vulnerability scans, SIEM export, support/SLA docs, security whitepaper.

Do Not Launch The Paid Self-Hosted Image If

- [ ] The API still requires a Cloudflare account, Wrangler dev, Durable Object emulation, or D1-only persistence.
- [ ] Secrets, note plaintext, URL fragments, passwords, or recovery material can appear in application logs.
- [ ] There is no documented backup and restore path for customer data.
- [ ] There is no admin bootstrap and recovery procedure.
- [ ] There is no identity integration path for OIDC or SAML.
- [ ] The metadata model and audit log contents are not documented for legal/security review.
- [ ] There is no upgrade procedure with rollback guidance.

Implementation Roadmap

The roadmap is ordered by dependency. Storage and runtime abstraction must come before advanced enterprise features because SSO, audit export, licensing, and retention all depend on stable organization and persistence models.

Phase	Goal	Key Deliverables	Exit Criteria
0	Preview packaging	Compose preview, env example, docs, health checks.	Engineers can run the app locally in containers and understand limitations.
1	Native runtime	API container, web static container, DB adapter, Redis/TTL adapter.	No Cloudflare account required for local self-hosted operation.
2	Enterprise identity	Org model, admin/member/auditor roles, OIDC login, admin bootstrap.	Company can manage users without PrivateNote staff.
3	Governance	Audit logs, retention policies, internal-only mode, recipient verification policy.	Security teams can enforce and review usage.
4	Operations	Backups, migrations, metrics, structured logs, upgrade/rollback docs.	IT can operate the system safely.
5	Hardening and launch	Signed images, SBOM, scans, SIEM export, security docs, license file.	Procurement and security review can proceed.

MVP Priorities

Priority	Include Before Beta	Defer
P0	Native API, PostgreSQL, OIDC, admin bootstrap, retention policy, audit log, backup/restore.	SCIM, SAML, Helm, hardware-backed keys.
P1	API tokens, SIEM export, internal-only mode, license file, image signing, SBOM.	Air-gap installer, advanced RBAC.
P2	Polish: admin UX, metrics dashboard, setup wizard, support bundle export.	Multi-region enterprise cloud automation.

1. Deployment And Packaging

- [ ] Production Docker Compose with web, api, db, and optional redis services.
- [ ] Production static web image served by Nginx, Caddy, or an equivalent minimal server.
- [ ] Native API image that does not require Wrangler, Cloudflare account credentials, or remote bindings.
- [ ] PostgreSQL service for durable enterprise data.
- [ ] Redis or equivalent TTL store for short-lived state, rate limits, and verification flows.
- [ ] Reverse proxy and TLS deployment guide.
- [ ] Environment variable reference with examples and safe defaults.
- [ ] Health, readiness, and liveness endpoints.

Exit Criteria
A fresh VM can run the product with docker compose up, using only customer-controlled containers and volumes.

2. Storage And Runtime Abstraction

- [ ] Create note storage interface independent of Durable Objects.
- [ ] Create auth storage interface independent of D1-specific APIs.
- [ ] Create KV/TTL interface independent of Cloudflare KV.
- [ ] Implement PostgreSQL adapter for notes metadata, auth, audit logs, and policies.
- [ ] Implement Redis or database-backed TTL adapter for short-lived tokens.
- [ ] Migration tooling for schema creation and upgrades.
- [ ] Data retention cleanup job that runs inside the self-hosted deployment.

Exit Criteria
The same API behavior works on standard containers with PostgreSQL/Redis and does not depend on Cloudflare primitives.

3. Core Security Model

- [ ] Preserve client-side encryption and URL fragment key handling.
- [ ] Document exact metadata stored server-side.
- [ ] Prove plaintext note content is never logged or persisted server-side.
- [ ] Configurable maximum note size.
- [ ] Configurable default and maximum TTL.
- [ ] Configurable burn-after-read and read-count policy.
- [ ] Internal-only mode that prevents public internet note-link behavior when enabled.
- [ ] Threat model covering server compromise, client compromise, admin misuse, and browser extension risk.

Exit Criteria
Security reviewers can understand what data exists where, what is protected, and what PrivateNote cannot protect against.

4. Identity And Access

- [ ] Local admin bootstrap flow for first deployment.
- [ ] OIDC login for enterprise identity providers.
- [ ] SAML support decision: defer unless a buyer requires it.
- [ ] Admin, member, and auditor roles.
- [ ] Session management and session revocation.
- [ ] Domain allowlist and email verification policy.
- [ ] Account deactivation and transfer/recovery flow.
- [ ] Admin reset procedure for break-glass scenarios.

Exit Criteria
A company can onboard, manage, and deactivate users without vendor involvement.

5. Organization Model And Admin Console

- [ ] Organization table and organization-scoped users.
- [ ] Organization-wide settings and policy defaults.
- [ ] Admin dashboard for users, sessions, policies, audit logs, and license status.
- [ ] Invite, deactivate, and role-change workflows.
- [ ] Usage metrics that do not expose plaintext content.
- [ ] Deployment status panel with version, storage health, and background job status.

Exit Criteria
Admins can operate the deployment from the UI for common tasks.

6. Audit, Compliance, And Export

- [ ] Audit sign-in, sign-out, failed login, and session revocation events.
- [ ] Audit note creation metadata without note content.
- [ ] Audit note access metadata without note content.
- [ ] Audit admin actions, policy changes, and API token use.
- [ ] CSV and JSON audit export.
- [ ] Configurable audit retention.
- [ ] SIEM export through webhook, syslog, or documented file sink.
- [ ] Audit event schema documentation.

Exit Criteria
Security teams can review sensitive activity and export events to their existing monitoring stack.

7. Policy Controls

- [ ] Default note expiry.
- [ ] Maximum allowed expiry.
- [ ] Force burn-after-read.
- [ ] Disable unlimited reads.
- [ ] Require recipient verification.
- [ ] Restrict external recipient domains.
- [ ] Disable AI features by policy.
- [ ] API token policy: scopes, expiration, revocation.

Exit Criteria
Admins can enforce organization-wide safe defaults instead of relying on individual user choices.

8. Recipient Verification

- [ ] Optional recipient email binding when a note is created.
- [ ] Recipient verification email flow before note reveal.
- [ ] Verification link TTL and single-use behavior.
- [ ] Audit event for verification and reveal attempts.
- [ ] Policy to require recipient verification for all notes or for external domains only.

Exit Criteria
Organizations can reduce accidental forwarding risk while preserving encrypted handoff workflows.

9. API And Integration Surface

- [ ] Documented internal API for creating notes.
- [ ] API tokens with scopes and expiration.
- [ ] Token revocation and rotation.
- [ ] Rate limits and abuse controls.
- [ ] OpenAPI specification.
- [ ] Audit events for API use.
- [ ] Versioned endpoints and compatibility policy.

Exit Criteria
Internal systems and developer tools can create notes safely without bypassing policy or audit controls.

10. Licensing And Offline Operation

- [ ] Offline license file format.
- [ ] License status visible in admin dashboard.
- [ ] Grace-period handling.
- [ ] User/deployment limit enforcement strategy.
- [ ] No hard dependency on outbound license checks.
- [ ] License renewal and replacement procedure.

Exit Criteria
A customer can run in a restricted network while still using a commercial license model.

11. Operations And Reliability

- [ ] Structured JSON logs.
- [ ] Configurable log level.
- [ ] Metrics endpoint or Prometheus export.
- [ ] Database migration command.
- [ ] Backup and restore guide tested against a fresh environment.
- [ ] Upgrade and rollback guide.
- [ ] Disaster recovery procedure.
- [ ] Support bundle export that excludes secrets and note plaintext.

Exit Criteria
Customer IT can run, monitor, upgrade, and recover the deployment without guesswork.

12. Hardening And Supply Chain

- [ ] Non-root containers.
- [ ] Pinned base images.
- [ ] Signed images.
- [ ] SBOM generation.
- [ ] Vulnerability scan output in CI.
- [ ] Read-only root filesystem where practical.
- [ ] Minimal outbound network mode.
- [ ] Secret rotation guide.
- [ ] Security headers and secure cookie settings verified in self-host mode.

Exit Criteria
Security review can evaluate the artifact, its dependencies, and its runtime posture.

Launch Artifacts Required

Enterprise buyers do not only evaluate features. They evaluate operational maturity, security posture, vendor readiness, and procurement risk. These artifacts should exist before a paid self-hosted launch.

Artifact	Purpose	Required For
Deployment guide	Step-by-step install, reverse proxy, TLS, env config, volumes.	Beta
Backup/restore guide	Database and file/volume recovery procedure.	Beta
Upgrade/rollback guide	Version upgrades, migrations, rollback plan.	Beta
Security architecture whitepaper	Encryption model, data flow, metadata, trust boundaries.	Beta
Threat model	Explicit risks and non-goals.	Beta
Admin guide	Users, roles, policies, audits, licensing.	Beta
OpenAPI spec	API use and integration stability.	Beta
SBOM	Dependency transparency.	GA
Image signing docs	Artifact authenticity.	GA
Compliance FAQ	Procurement/security questionnaire support.	GA
Support policy	SLA, severity definitions, patch process.	GA

Security And Compliance Questions To Answer

- [ ] What exact data is stored for a note?
- [ ] Can admins read note contents? The answer must remain no unless the client shares plaintext elsewhere.
- [ ] What appears in logs, audit events, backups, and metrics?
- [ ] Can the deployment run with no outbound network after images are pulled?
- [ ] How are secrets configured and rotated?
- [ ] How are users provisioned and deprovisioned?
- [ ] How are vulnerabilities disclosed and patched?
- [ ] How does a customer prove which image version is running?
- [ ] How are audit logs retained and exported?
- [ ] What is the disaster recovery procedure and RPO/RTO assumption?

Beta Test Plan

Test Area	Minimum Scenarios
Install	Fresh VM, docker compose up, reverse proxy, TLS, first admin bootstrap.
Encryption	Create/reveal note, confirm URL fragment key is not sent in API requests, confirm ciphertext-only persistence.
Retention	Default TTL, maximum TTL, forced burn-after-read, cleanup jobs.
Identity	OIDC login, session revocation, user deactivation, admin recovery.
Audit	Sign-in, note create, note access, policy change, admin action, API token use, export.
Backup/restore	Backup database, restore into fresh environment, verify users/policies/audit and note metadata.
Upgrade	Upgrade from prior image, run migrations, rollback with documented limits.
Internal-only mode	Verify public/external recipient behavior is blocked according to policy.
Observability	Health checks, metrics, structured logs, no plaintext leakage.
Security review	SBOM, scan output, signed image verification, threat model review.

Deferred Until After MVP

- SCIM provisioning.
- SAML if OIDC satisfies initial design partners.
- Kubernetes Helm chart.
- Air-gap installer and offline update bundles.
- Hardware-backed keys and HSM/KMS integrations.
- Advanced RBAC beyond admin, member, and auditor.
- Full enterprise cloud automation.

Final Launch Gate

Launch Decision
Launch self-hosted as a paid enterprise beta only when the deployment no longer depends on Cloudflare runtime primitives, has customer-controlled persistence, supports enterprise identity, provides audit and policy controls, and includes the operational/security documentation buyers need to approve it.